

ISO 27001:2022

Readiness Self-Assessment Report

Company: Nikuu
Date: 01 June 2026

Overall Readiness: 48%

■ Moderate — Several gaps identified. Priority improvements recommended.

Executive Summary

The following table shows the readiness score for each of the 7 Annex A domains. Scores are calculated as the percentage of controls within each domain that are adequately addressed based on your responses.

Domain	Score	Status	Coverage
Organizational Controls	43%	■	3/7
People Controls	50%	■	2/4
Physical Controls	75%	■	3/4
Technological Controls	38%	■	3/8
Asset Management	33%	■	1/3
Cryptography	50%	■	1/2
Incident Management	50%	■	1/2

Overall Score: 48%

Gap Analysis by Domain

For each domain, controls that were not adequately addressed are listed below with their description and suggested next steps.

■ Organizational Controls — Score: 43% (3/7 covered)

A.5.19

Description: Information security requirements for supplier relationships shall be defined and agreed.

Recommended Action: Define security requirements for supplier contracts. Conduct risk assessments for critical vendors.

A.5.20

Description: Suppliers shall be reviewed regularly for compliance with information security requirements.

Recommended Action: Establish a regular review process for supplier compliance with security requirements.

A.5.35

Description: Internal audits shall be conducted at planned intervals to verify compliance with information security requirements.

Recommended Action: Create an internal audit programme. Conduct audits at planned intervals and track remediation.

A.5.29

Description: Business continuity plans shall be developed and maintained to ensure continuity of information security.

Recommended Action: Develop a Business Continuity Plan that covers IT systems and data recovery.

A.5.30

Description: Business continuity plans shall be tested and reviewed regularly.

Recommended Action: Schedule regular testing of business continuity plans (at least annually). Document test results.

A.5.31

Description: Legal, statutory, regulatory and contractual requirements relevant to information security shall be identified and documented.

Recommended Action: Create a legal and compliance register. Monitor changes in data protection regulations (e.g., GDPR).

A.5.34

Description: Privacy and protection of personally identifiable information shall be ensured.

Recommended Action: Implement privacy controls for personal data. Appoint a Data Protection Officer if required.

■ People Controls — Score: 50% (2/4 covered)

A.6.1

Description: Background verification checks on all candidates for employment shall be conducted prior to joining.

Recommended Action: Implement a formal background check process for all new hires, including criminal record and reference checks.

A.6.5

Description: Access rights of personnel shall be removed upon termination of their employment or contract.

Recommended Action: Create an offboarding checklist that ensures all access is revoked within 24 hours of termination.

■ Physical Controls — Score: 75% (3/4 covered)

A.7.3

Description: Visitors to secure areas shall be supervised and their access logged.

Recommended Action: Establish a visitor access policy. Require visitor registration, badges, and escorts to sensitive areas.

■ Technological Controls — Score: 38% (3/8 covered)

A.8.5

Description: Secure authentication methods, such as multi-factor authentication, shall be implemented where appropriate.

Recommended Action: Implement multi-factor authentication (MFA) for email, VPN, admin accounts, and remote access.

A.8.2

Description: Access to information and systems shall be revoked or modified when no longer required.

Recommended Action: Implement a process to promptly revoke or modify access when personnel change roles or leave the organization.

A.8.3

Description: Access rights shall be reviewed at regular intervals.

Recommended Action: Conduct quarterly access rights reviews. Verify that user permissions align with current job requirements.

A.8.7

Description: Malware protection mechanisms shall be implemented and maintained on all endpoint devices.

Recommended Action: Deploy endpoint protection (EDR/antivirus) on all devices. Ensure definitions are updated automatically.

A.8.20

Description: Network security controls shall be implemented to protect services from unauthorized access.

Recommended Action: Implement network security controls including firewalls, network segmentation, and access control lists.

A.8.21

Description: Security mechanisms shall be applied to web applications to protect against web-based attacks.

Recommended Action: Deploy a Web Application Firewall (WAF) and implement security headers for web applications.

A.8.8

Description: Security patches shall be applied in a timely manner to protect against known vulnerabilities.

Recommended Action: Establish a patch management policy. Apply critical patches within 14 days and maintain a patch schedule.

A.8.25

Description: Testing of security measures shall be conducted at planned intervals to verify effectiveness.

Recommended Action: Schedule regular penetration tests and vulnerability scans. Remediate findings based on severity.

■ **Asset Management — Score: 33% (1/3 covered)**

A.5.9

Description: An inventory of information assets shall be maintained and kept current.

Recommended Action: Implement an asset management system (e.g., CMDB) to maintain a current inventory of all information assets.

A.5.11

Description: Assets shall be returned and media disposal shall be carried out securely.

Recommended Action: Create a secure disposal policy. Use certified data destruction services for media and devices.

A.7.14

Description: Equipment containing storage media shall be verified that sensitive data has been securely erased or destroyed.

Recommended Action: Implement secure media disposal procedures including secure erase, physical destruction, and certificate of destruction.

■ **Cryptography — Score: 50% (1/2 covered)**

A.8.24

Description: Cryptographic controls shall be used to protect the confidentiality of information on mobile devices.

Recommended Action: Enable full-disk encryption (e.g., BitLocker, FileVault) on all laptops and mobile devices.

A.5.10

Description: Information shall be protected in transit and at rest using appropriate cryptographic methods.

Recommended Action: Identify data flows and implement encryption for sensitive data in transit and at rest.

■ Incident Management — Score: 50% (1/2 covered)

A.5.27

Description: Information security incidents shall be documented, reported, and collected as evidence.

Recommended Action: Implement a security incident logging system. Ensure all incidents are documented with timestamps and evidence.

A.5.28

Description: Lessons learned from incidents shall be documented and used to improve the security posture.

Recommended Action: Establish a post-incident review process. Document lessons learned and update security controls accordingly.

Full Q&A; Transcript

The complete list of all 30 questions and the responses provided during the assessment.

Q1. [Q01] Do you have a documented Information Security Policy?

Answer: ou should answer based on reality: * Yes — if your organization has a written Information Security Policy that has been formally documented and communicated.

Matched Controls: A.5.1

Q2. [Q02] Are roles and responsibilities for information security clearly defined?

Answer: es. Roles and responsibilities for information security are clearly defined and assigned. Responsibilities include security governance, access management, secure development practices, incident response, vulnerability management, and compliance oversight.

Matched Controls: A.5.2

Q3. [Q03] Do you have a process for managing information security risks?

Answer: Yes. We maintain an information security risk management process to identify, assess, prioritize, and mitigate risks to our systems and data. Risks are evaluated based on likelihood and impact, tracked through remediation plans, and reviewed periodically. Security controls are implemented to reduce identified risks, and significant risks are escalated to management for review.

Matched Controls: A.5.8

Q4. [Q04] Is there a process for handling supplier/third-party security?

Answer: no

Matched Controls: None

Q5. [Q05] Do you conduct internal information security audits?

Answer: no

Matched Controls: None

Q6. [Q06] Is there a business continuity plan that covers IT/data?

Answer: no

Matched Controls: None

Q7. [Q07] Do you have a legal/compliance register for data protection laws?

Answer: no

Matched Controls: None

Q8. [Q08] Do you conduct background checks on new employees?

Answer: no

Matched Controls: None

Q9. [Q09] Is security training provided to all staff?

Answer: Yes. Yes. All staff receive information security awareness training covering topics such as password security, phishing prevention, data protection, acceptable use, incident reporting, and secure handling of sensitive information. Training is provided during onboarding and refreshed periodically.

Matched Controls: A.6.3

Q10. [Q10] Do employees sign confidentiality/NDA agreements?

Answer: Do employees sign confidentiality/NDA agreements?

Matched Controls: A.6.2

Q11. [Q11] Is there a process for offboarding employees (revoking access)?

Answer: no

Matched Controls: None

Q12. [Q12] Are server rooms / data centres physically secured?

Answer: o

Matched Controls: A.7.1, A.7.2

Q13. [Q13] Do you control visitor access to sensitive areas?

Answer: oo

Matched Controls: None

Q14. [Q14] Is equipment protected against environmental threats?

Answer: oo

Matched Controls: A.7.8

Q15. [Q15] Do you have a clear desk and clear screen policy?

Answer: o

Matched Controls: A.7.7

Q16. [Q16] Do you use multi-factor authentication (MFA)?

Answer: oo

Matched Controls: None

Q17. [Q17] Are access rights reviewed and revoked when no longer needed?

Answer: oo

Matched Controls: None

Q18. [Q18] Are all systems patched and updated regularly?

Answer: o

Matched Controls: A.8.8

Q19. [Q19] Do you have antivirus / endpoint protection on all devices?

Answer: oo

Matched Controls: None

Q20. [Q20] Is network traffic monitored for threats?

Answer: o

Matched Controls: A.8.16

Q21. [Q21] Do you have a Web Application Firewall (WAF) or similar?

Answer: oo

Matched Controls: None

Q22. [Q22] Is data backed up regularly and tested for restore?

Answer: o

Matched Controls: A.8.13

Q23. [Q23] Do you conduct penetration tests or vulnerability scans?

Answer: 00

Matched Controls: None

Q24. [Q24] Do you maintain an inventory of all information assets?

Answer: 00

Matched Controls: None

Q25. [Q25] Is information classified according to sensitivity?

Answer: 0

Matched Controls: [A.5.12](#)

Q26. [Q26] Do you have a policy for secure disposal of media/devices?

Answer: 00

Matched Controls: None

Q27. [Q27] Are laptops and mobile devices encrypted?

Answer: 0

Matched Controls: [A.8.24](#)

Q28. [Q28] Is sensitive data encrypted at rest and in transit?

Answer: 00

Matched Controls: None

Q29. [Q29] Do you have an incident response plan?

Answer: 0

Matched Controls: [A.5.24](#), [A.5.25](#)

Q30. [Q30] Are security incidents logged and reviewed after resolution?

Answer: 00

Matched Controls: None